

What is Content Discovery?

Finding things on a website that aren't immediately visible and weren't always intended for public access (staff portals, old versions, backup files, config files, admin panels).

Three Main Methods: Manual, Automated, OSINT

Manual Discovery - Key Locations to Check:

Robots.txt

- Tells search engines which pages they can/can't show
- Often contains restricted areas (admin portals, customer files)
- Check: <http://website.com/robots.txt>

Favicon

- Small icon in browser tab
- If default framework icon left unchanged, can identify the framework
- OWASP favicon database: https://wiki.owasp.org/index.php/OWASP_favicon_database
- Get favicon hash: `curl https://website.com/favicon.ico | md5sum`

Sitemap.xml

- Lists files the owner wants listed on search engines
- May contain old/forgotten pages still active
- Check: <http://website.com/sitemap.xml>

HTTP Headers

- Can reveal server software and versions
- Check with: `curl http://website.com -v`
- Look for: Server, X-Powered-By headers

Framework Stack

- Check page source for comments, copyright notices, credits
 - Framework documentation may reveal admin portals or hidden paths
-

OSINT Discovery Methods:

Google Dorking:

- site:tryhackme.com - results only from specified domain
- inurl:admin - results with word in URL
- filetype:pdf - results with specific file extension
- intitle:admin - results with word in title

Wappalyzer: Browser extension that identifies website technologies

Wayback Machine: <https://archive.org/web/> - Historical website archive, may reveal old active pages

GitHub: Search for company/website names to find repositories with source code, passwords, hidden content

S3 Buckets: Format: `http(s)://{name}.s3.amazonaws.com`

- Look for misconfigured permissions
 - Common naming: {name}-assets, {name}-www, {name}-public, {name}-private
-

Automated Discovery:

Wordlists: Text files with commonly used directory/file names

- SecLists: <https://github.com/danielmiessler/SecLists>

Tools:

ffuf:

```
ffuf -w /path/to/wordlist -u http://website.com/FUZZ
```

dirb:

```
dirb http://website.com/ /path/to/wordlist
```

gobuster:

```
gobuster dir --url http://website.com/ -w /path/to/wordlist
```